API Security Risk Analysis Report

By: Vaishnavi Vijay Naik

Internship: Cyber Security – Future Interns

Date: 26 APRIL 2026

Introduction

API (Application Programming Interface) security is a critical component of modern application security, as APIs are widely used in web applications, mobile applications, and SaaS platforms. APIs enable communication between different software systems and often handle sensitive data such as user information and authentication details.

However, insecure APIs can become a major attack vector if proper security controls are not implemented. Attackers can exploit weak authentication, excessive data exposure, or lack of access control to gain unauthorized access to sensitive information.

This report focuses on analyzing a public API to identify potential security risks, evaluate its authentication and data exposure mechanisms, and provide recommendations to improve its security posture.

API Overview

The API selected for this analysis is JSONPlaceholder, a publicly available REST API designed for testing and prototyping. It provides multiple endpoints such as `/users`, `/posts`, `/comments`, and others.

For this analysis, the /users endpoint was selected:

https://jsonplaceholder.typicode.com/users

This endpoint returns user-related data in JSON format and is commonly used for testing frontend and backend integrations.

Tools Used

The following tools were used for API testing and analysis:

- Postman – for sending API requests and analyzing responses
- Browser DevTools – for inspecting network requests, headers, and API responses

API Testing and Observation

The API was tested using Postman and Browser DevTools. A GET request was sent to the `/users` endpoint to retrieve user data. The response and request details were further inspected using Browser DevTools to analyze headers and response structure.

The response returned a list of users along with detailed information including:

- Name
- Username
- Email address
- Phone number
- Full address (street, city, ZIP code, geolocation)
- Company details

It was observed that:

- The API did <u>not require any authentication</u>
- The data was accessible directly through the endpoint
- No API key or token was required to access the response

The response includes user details such as name, email, phone number, and address, which are accessible without authentication.

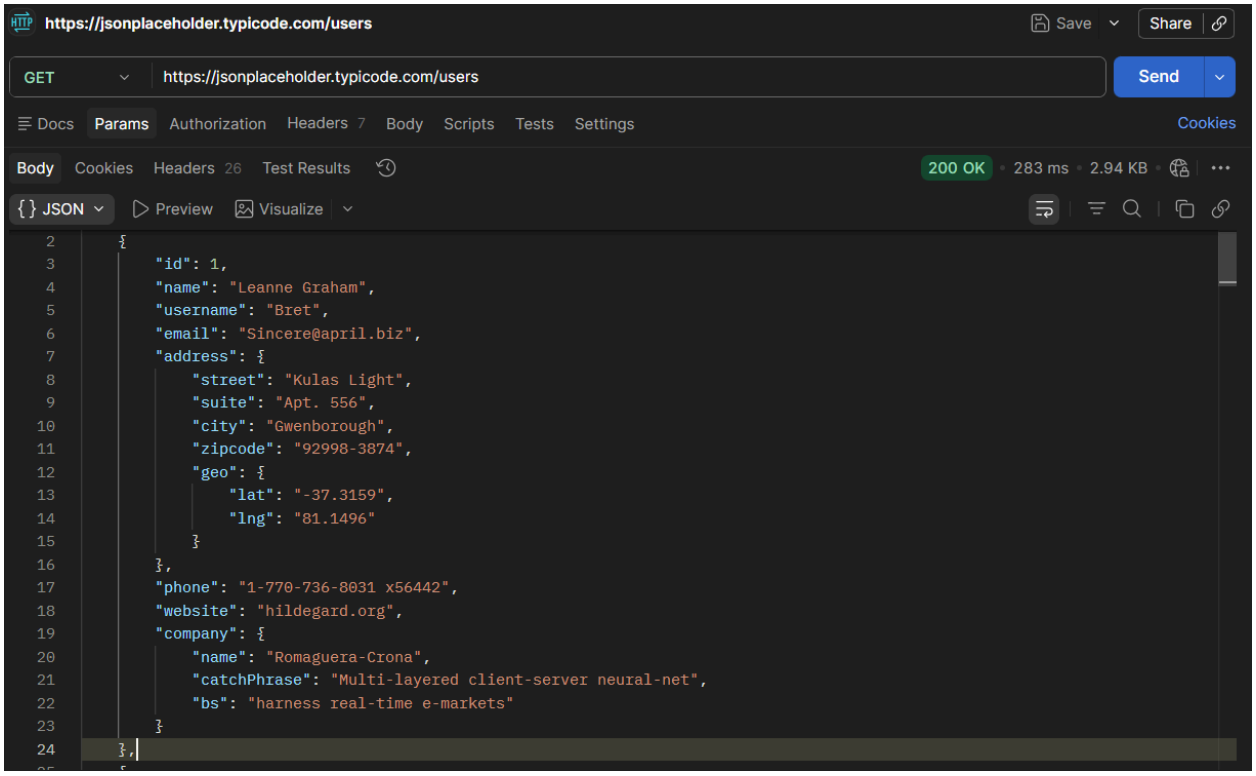
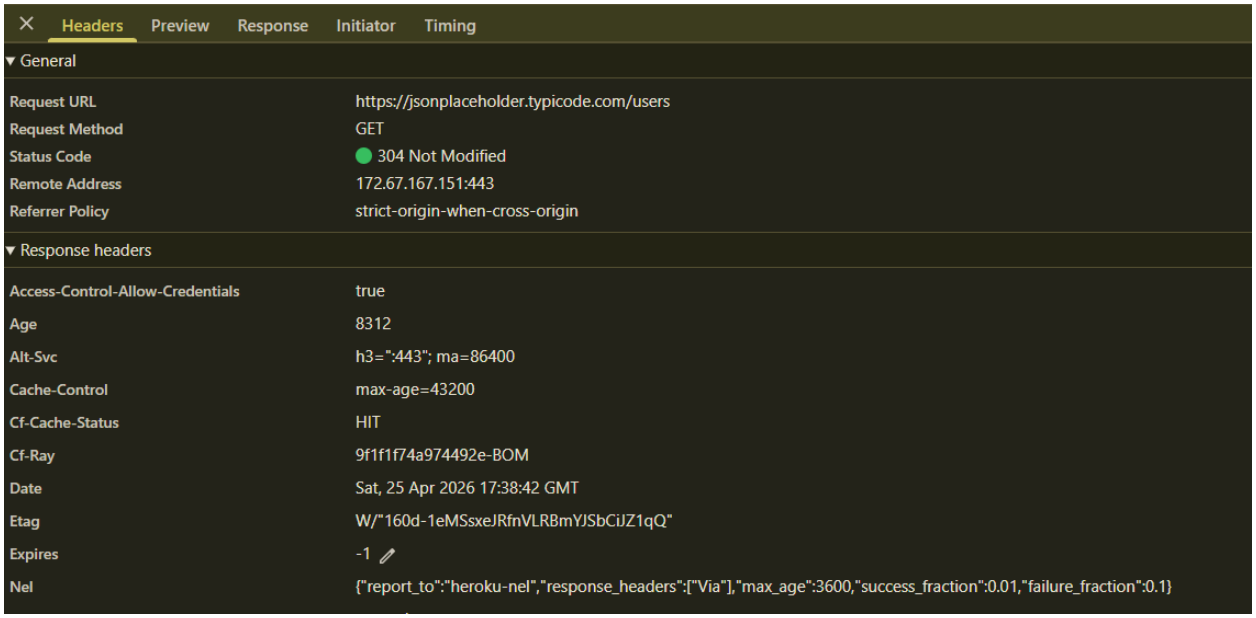


Figure1: API response showing user data retrieved without authentication



Headers | Preview | Response | Initiator | Timing

▾ General

Request URL	https://jsonplaceholder.typicode.com/users
Request Method	GET
Status Code	304 Not Modified
Remote Address	172.67.167.151:443
Referrer Policy	strict-origin-when-cross-origin

▾ Response headers

Access-Control-Allow-Credentials	true
Age	8312
Alt-Svc	h3=":443"; ma=86400
Cache-Control	max-age=43200
Cf-Cache-Status	HIT
Cf-Ray	9f1f1f74a974492e-BOM
Date	Sat, 25 Apr 2026 17:38:42 GMT
Etag	W/"160d-1eMSsxeJRfnVLRBmYJSbCiJZ1qQ"
Expires	-1
Nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01,"failure_fraction":0.1}

Figure 2: Request headers inspected using Browser DevTools

Headers | Preview | Response | Initiator | Timing


```
[
  {
    "id": 1,
    "name": "Leanne Graham",
    "username": "Bret",
    "email": "Sincere@april.biz",
    "address": {
      "street": "Kulas Light",
      "suite": "Apt. 556",
      "city": "Gwenborough",
      "zipcode": "92998-3874",
      "geo": {
        "lat": "-37.3159",
        "lng": "81.1496"
      }
    },
    "phone": "1-770-736-8031 x56442",
    "website": "hildegard.org",
    "company": {
      "name": "Romaguera-Crona",
      "catchPhrase": "Multi-layered client-server neural-net",
      "bs": "harness real-time e-markets"
    }
  },
```


Figure 3: API response viewed in Browser DevTools

Authentication Analysis

Authentication is an important security control used to verify the identity of users or systems accessing an API.

In this case, the API does not implement any authentication mechanism such as:

- API keys
- Bearer tokens
- OAuth authentication

This means that any user can send a request to the API and retrieve data without any verification. While this may be acceptable for a testing API, in real-world applications this would be considered a serious security weakness.

Data Exposure Analysis

The API exposes a significant amount of user information in its response. This includes both basic and potentially sensitive data such as:

- Email addresses
- Phone numbers
- Full residential addresses
- Geographic coordinates (latitude and longitude)

This level of data exposure is unnecessary for most use cases and increases the risk of misuse. In real-world scenarios, APIs should follow the principle of **data minimization**, returning only the data required for functionality.

Identified Security Risks

1. No Authentication (High Severity)

The API allows unrestricted access to user data without requiring authentication. This makes it possible for anyone to access user information without authorization.

2. Excessive Data Exposure (High Severity)

The API returns detailed user information including email, phone number, and address. This increases the risk of sensitive data misuse and violates best practices for secure API design.

Risk Severity Assessment

Risk	Severity	Reason
No Authentication	High	Allows unrestricted access to data
Excessive Data Exposure	High	Sensitive information is publicly accessible

Both risks are classified as **High** because they directly impact data confidentiality and user privacy.

Business Impact

The identified security risks can have serious consequences for an organization:

- Unauthorized access to user data can lead to **data breaches**
- Exposed personal information can be used for **phishing or identity theft**
- Organizations may suffer **reputational damage** and loss of customer trust
- Legal and regulatory issues may arise due to **non-compliance with data protection laws**

Overall, insecure APIs can significantly impact both business operations and customer confidence.

Remediation Suggestions

To improve API security, the following measures are recommended:

- Implement authentication mechanisms such as API keys or OAuth tokens
- Restrict access to sensitive endpoints using proper authorization controls
- Limit the data returned in API responses (data minimization)
- Apply rate limiting to prevent abuse and excessive requests
- Validate and sanitize inputs to prevent injection attacks
- Monitor API activity and logs for suspicious behavior

Conclusion

API security is essential for protecting sensitive data and maintaining trust in modern applications. This analysis demonstrates how APIs without proper authentication and data protection mechanisms can expose critical information.

By implementing strong authentication, limiting data exposure, and following secure API design practices, organizations can significantly reduce security risks and improve their overall security posture.